

The background of the image features a dark blue gradient on the left, transitioning into a large, vibrant, abstract shape on the right. This shape is composed of overlapping curved segments in shades of orange, pink, and purple, creating a dynamic, modern aesthetic.

AWS re:Invent

NOV. 27 – DEC. 1, 2023 | LAS VEGAS, NV

SEC325

Protect your data using AWS services for defense in depth

Don Edwards

he/him
Worldwide Tech Leader, Identity
AWS

Peter M. O'Donnell

he/him
Principal Solutions Architect, Security
AWS

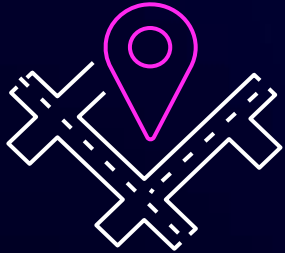


© 2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

What we together are talking about today

- What people mean when they say “data protection”
- Protecting data requires **assurance** via compliance
- Traditional forms of data protection – network controls, access controls, and encryption
- **Newer patterns to protect data**
- Protecting data also means ensuring persistence and durability

Compliance for privacy and data security



Meet data residency requirements

Choose an AWS Region, and AWS will not replicate it elsewhere unless you choose to do so



Encryption at scale

with keys managed by AWS KMS or manage your own encryption keys using FIPS 140-2 validated HSMs



Comply with local data privacy laws by controlling who can access content, its lifecycle, and its disposal



Access services and tools that enable you to build compliant infrastructure on top of AWS

Top 4 data protection use cases

Data in transit

Network encryption



Encrypt data as it moves between networks

Data at rest

Storage encryption



Easily encrypt data where it resides

Application credentials

Managed secrets



Protect secrets without management overhead

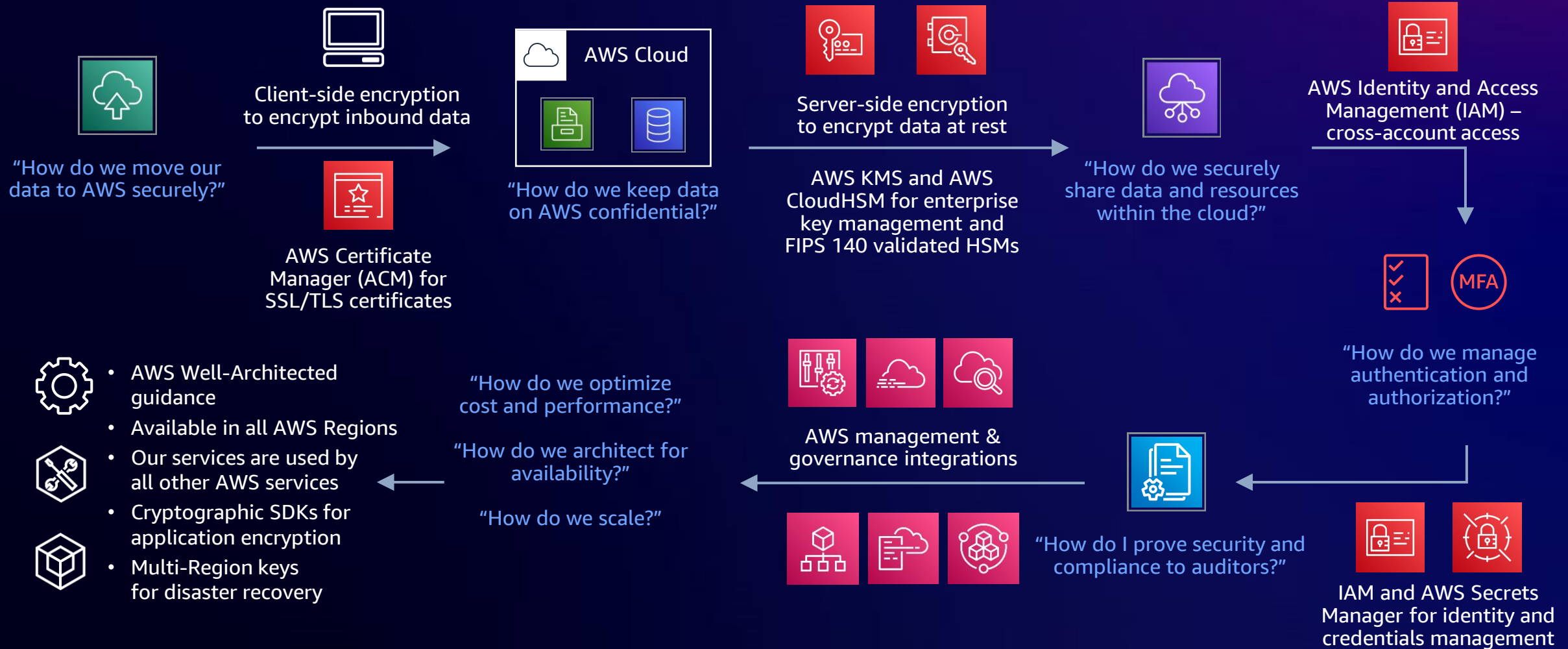
Lifecycle management

Automation



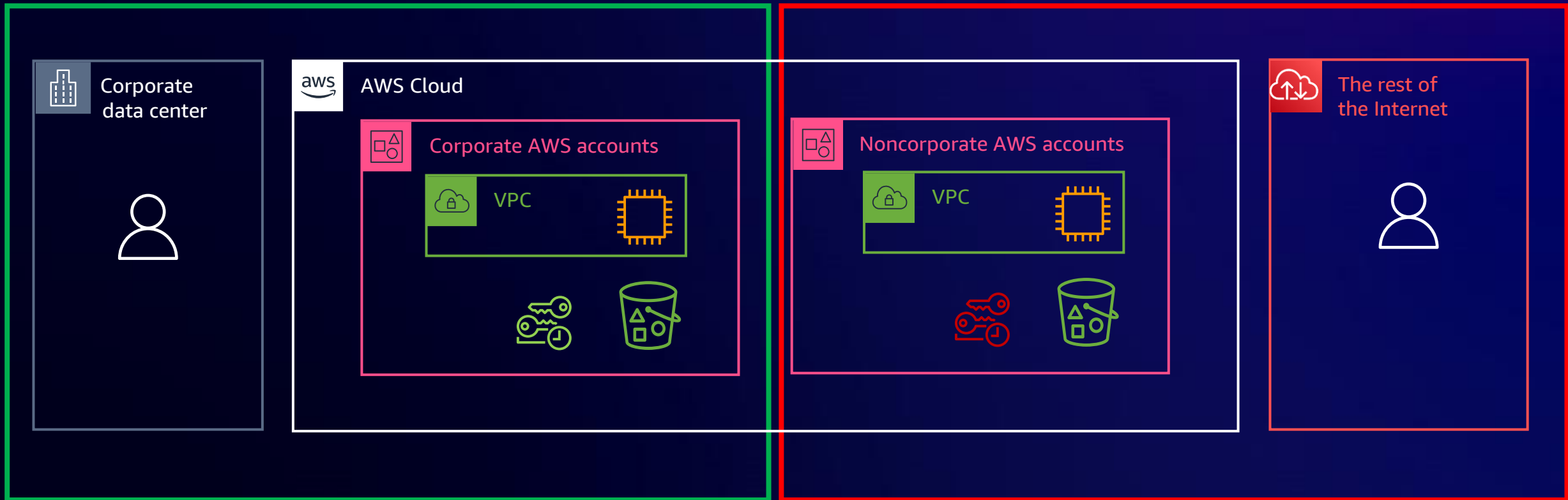
Make security easy and reduce human error

Data protection journey



What is a data perimeter?

A set of preventive guardrails in your AWS environment that help ensure only your **trusted identities** are accessing **trusted resources** from **expected networks**



Primary tools for your data perimeter

1

Service control policies (SCPs)

Your identities can access only trusted resources from expected networks

2

VPC endpoint policies

Your network can be used only by trusted identities to access only trusted resources

3

Resource-based policies

Your resources can be accessed only by trusted identities and from expected networks

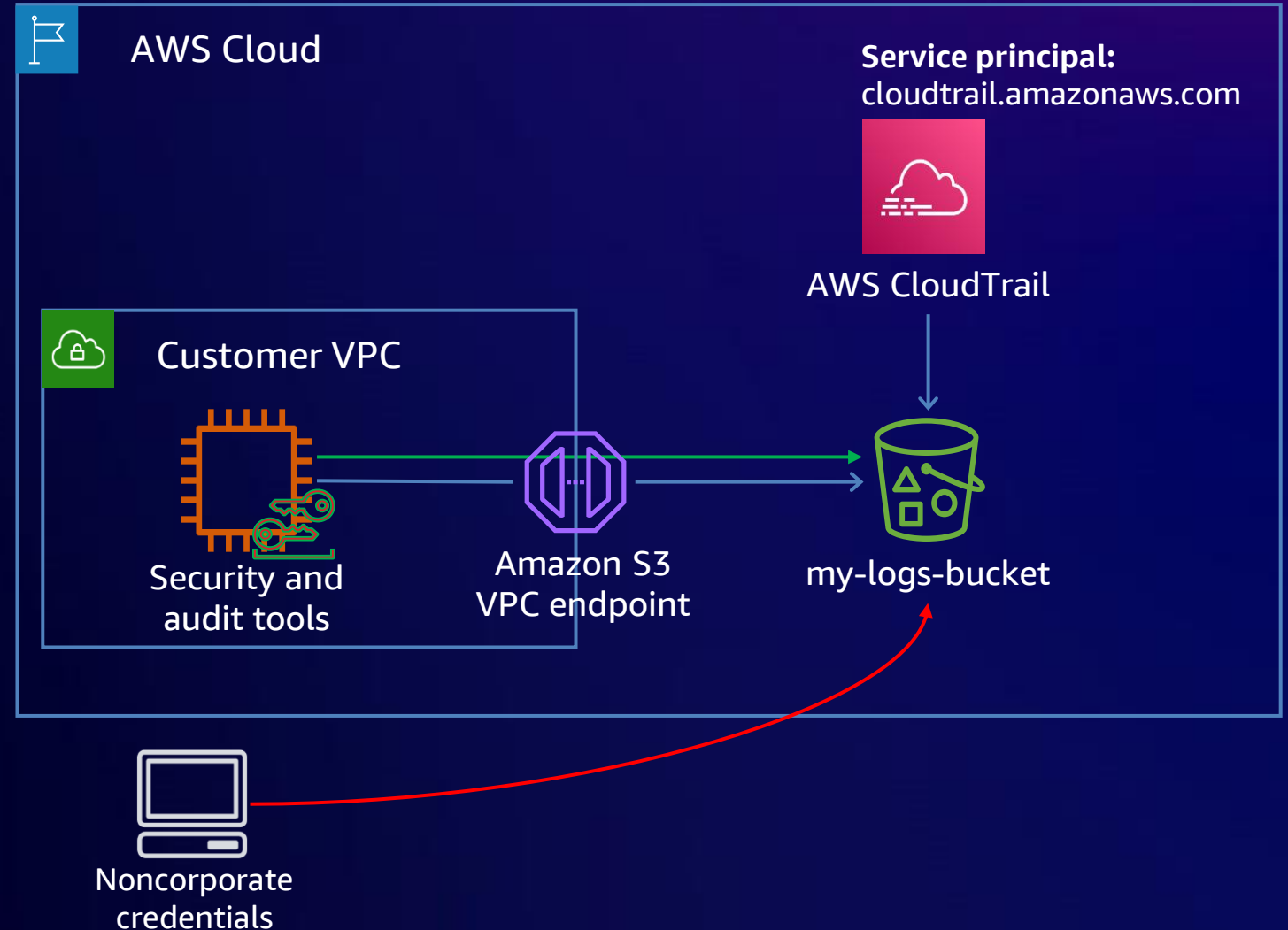
Data perimeter controls

Perimeter	Intent/control objective	Applied on	Using
Identity	Only trusted identities can access my resources	Resources	Resource-based policy
	Only trusted identities are allowed from my network	Network	VPC endpoint policy
Resource	My identities can access only trusted resources	Identities	SCP
	Only trusted resources can be accessed from my network	Network	VPC endpoint policy
Network	My identities can access resources only from expected networks	Identities	SCP
	My resources can only be accessed from expected networks	Resources	Resource-based policy

Identity perimeter on resources

ONLY TRUSTED IDENTITIES CAN ACCESS MY RESOURCES

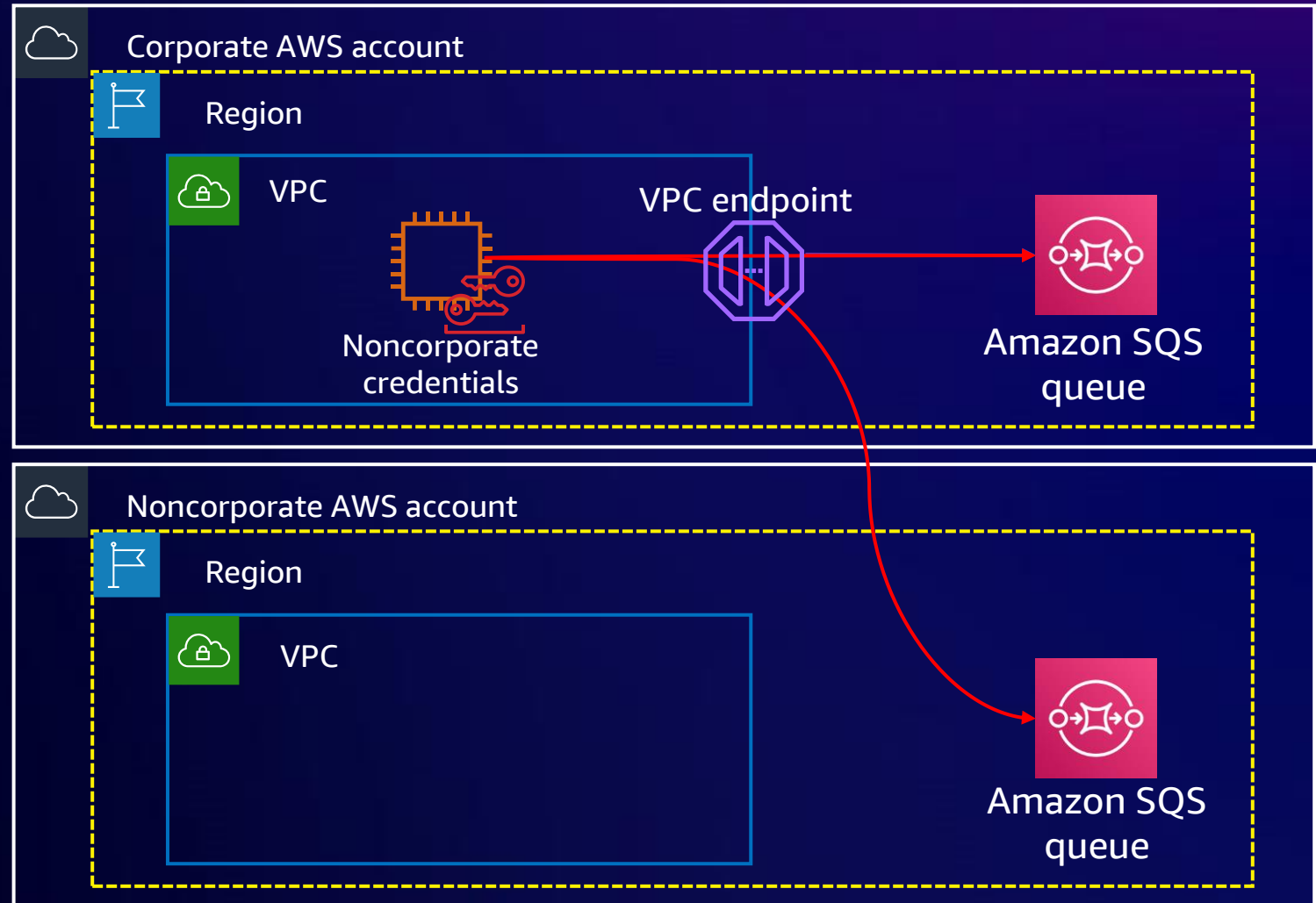
```
.....  
{  
  "Effect": "Deny",  
  "Principal": "*",  
  "Action": [  
    "s3:ListBucket",  
    "s3:PutObject*",  
    "s3:GetObject*"  
  ],  
  "Resource": [  
    "arn:aws:s3:::<my-data-bucket>",  
    "arn:aws:s3:::<my-data-bucket>/*"  
  ],  
  "Condition": {  
    "StringNotEqualsIfExists": {  
      "aws:PrincipalOrgID": "<o-xxxxxxx>"  
    },  
    "BoolIfExists": {  
      "aws:PrincipalIsAWSService": "false"  
    }  
  }  
}  
}  
.....
```



Identity perimeter on network

ONLY TRUSTED IDENTITIES ARE ALLOWED FROM MY NETWORK

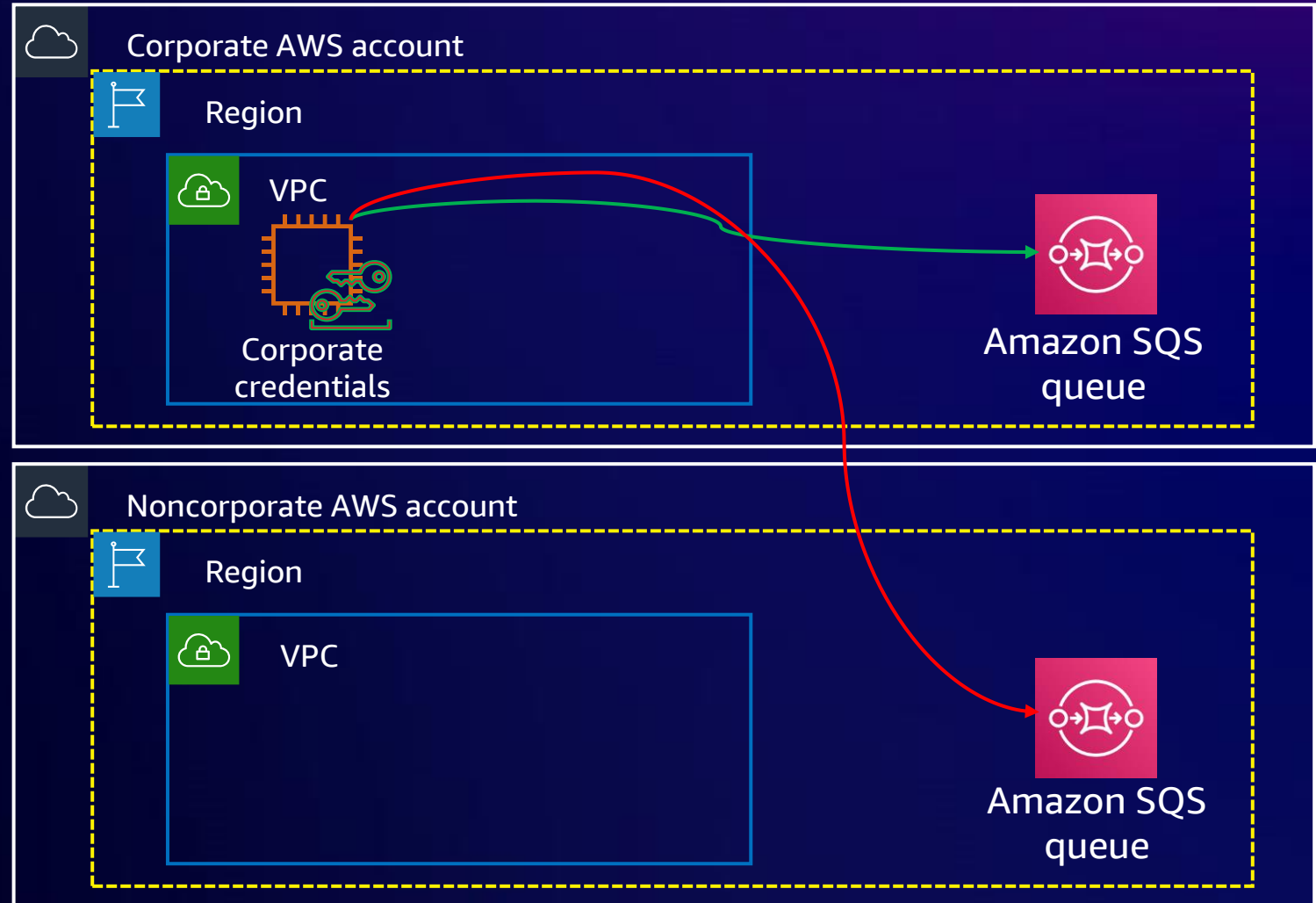
```
{
  "Statement": [
    {
      "Action": "*",
      "Effect": "Allow",
      "Resource": "*",
      "Principal": {
        "AWS": "*"
      },
      "Condition": {
        "StringEquals": {
          "aws:PrincipalOrgID":
            "o-xxxxxxxx"
        }
      }
    }
  ]
}
```



Resource perimeter on identity

MY IDENTITIES CAN ACCESS ONLY TRUSTED RESOURCES

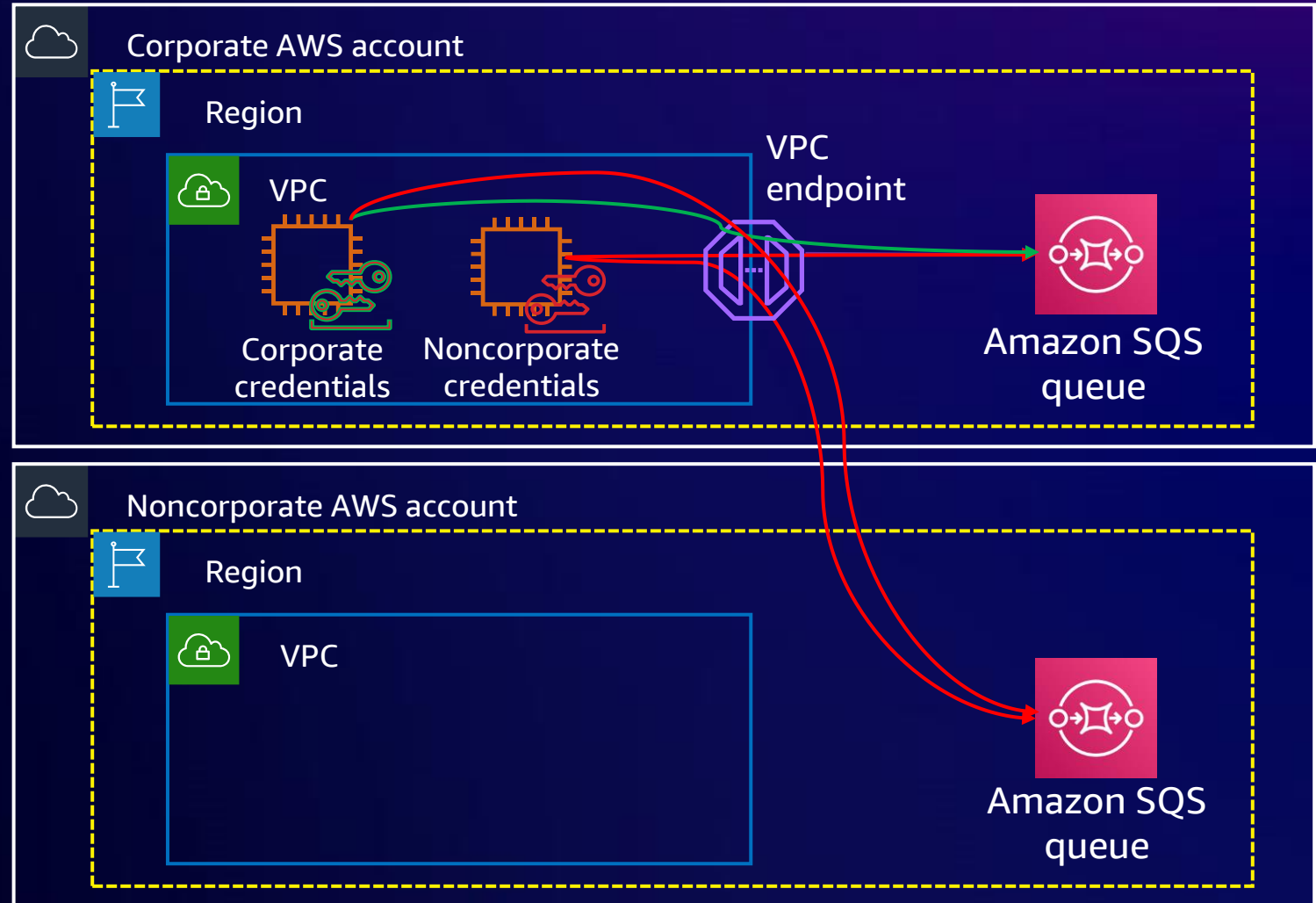
```
.....  
{  
  "Effect": "Deny",  
  "Action": [  
    "sqs:SendMessage"  
  ],  
  "Resource": "*",  
  "Condition": {  
    "StringNotEqualsIfExists ": {  
      "aws:ResourceOrgID ": "o-  
xxxxxxx"  
    }  
  }  
}  
.....
```



Resource perimeter on network

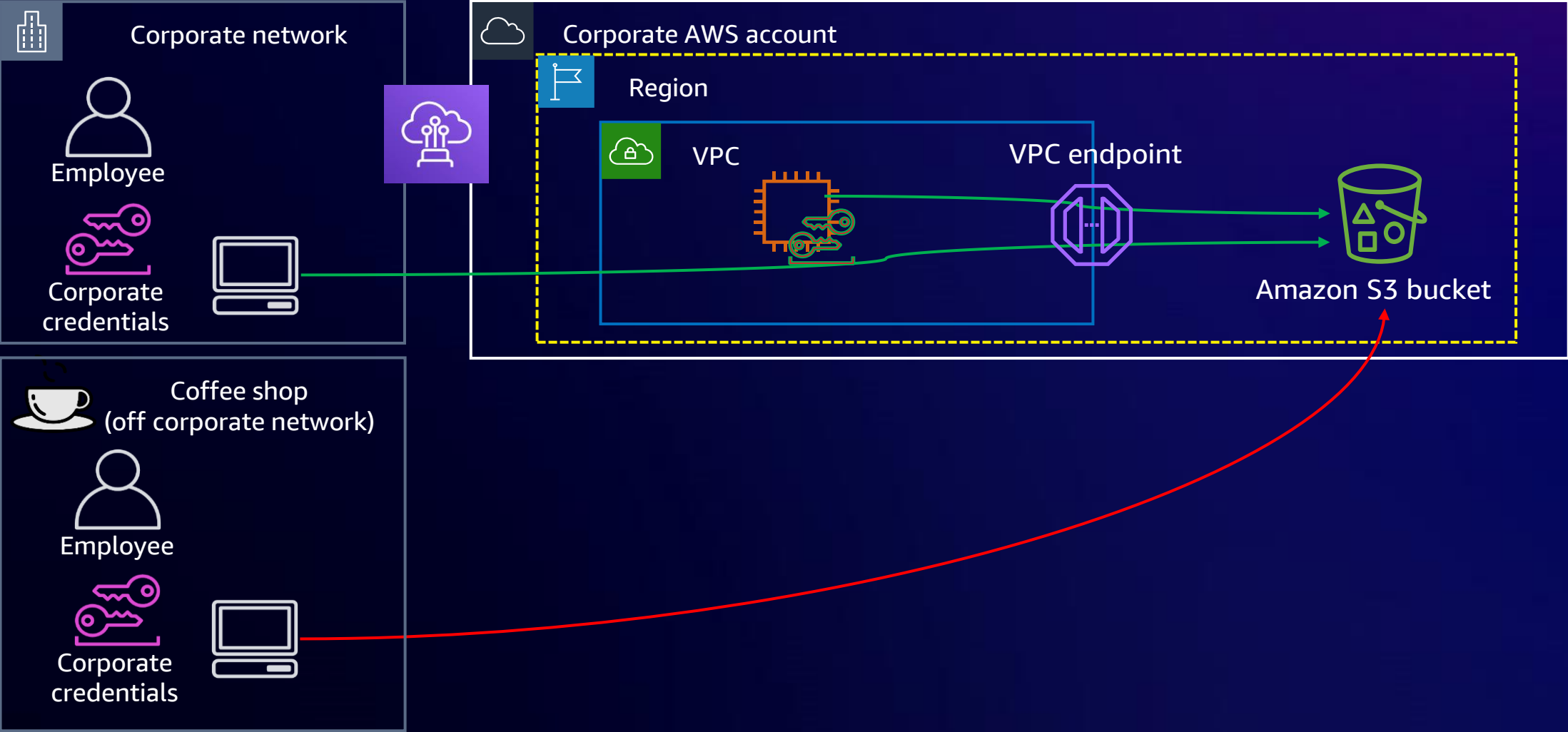
ONLY TRUSTED RESOURCES CAN BE ACCESSED FROM MY NETWORK

```
{
  "Statement": [
    {
      "Action": "*",
      "Effect": "Allow",
      "Resource": "*",
      "Principal": {
        "AWS": "*"
      },
      "Condition": {
        "StringEquals": {
          "aws:PrincipalOrgID": "o-xxxxxxxxxx",
          "aws:ResourceOrgID": "o-xxxxxxxxxx"
        }
      }
    }
  ]
}
```



Network perimeter on resource

MY RESOURCES CAN ONLY BE ACCESSED FROM EXPECTED NETWORKS



Types of encryption

Data at rest

Storage encryption



Data



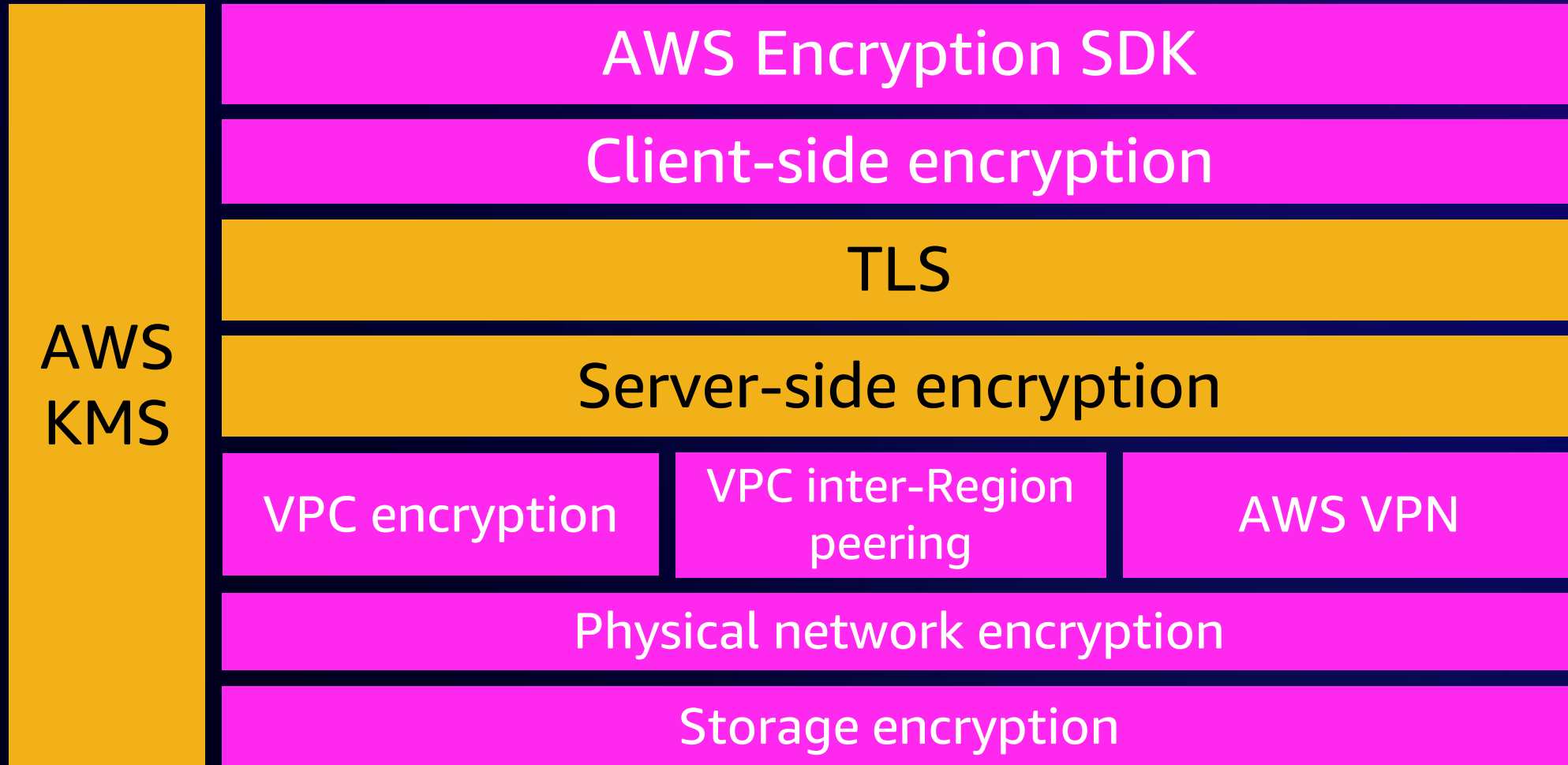
Amazon S3
bucket

Data in transit

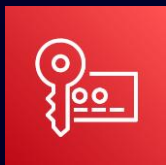
Network encryption



Encryption on AWS



Encryption key and trust protection is essential



AWS Key Management Service (AWS KMS)



AWS Identity and Access Management (IAM)



AWS Certificate Manager (ACM)



AWS Secrets Manager



Resource-based key management policies



IAM Roles Anywhere



Certificate authority management permissions

Security assurance and provable data protection

Notify me if my **desired encryption settings are modified**



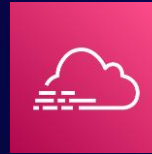
AWS Config

Utilize AWS Config managed rules to **monitor encryption configuration changes** in your AWS environment

Examples

- secretsmanager-secret-unused

Monitor **usage** of ACM certificates and KMS keys



AWS CloudTrail

Use AWS CloudTrail to **create detailed logs** of API calls to the AWS KMS and ACM services for audit purposes

An AWS KMS API action was called

- By who (user, account, IP)
- When (timestamp)
- Where, why (KMS key, AWS resource)

Audit **important lifecycle events** for certificates and KMS keys



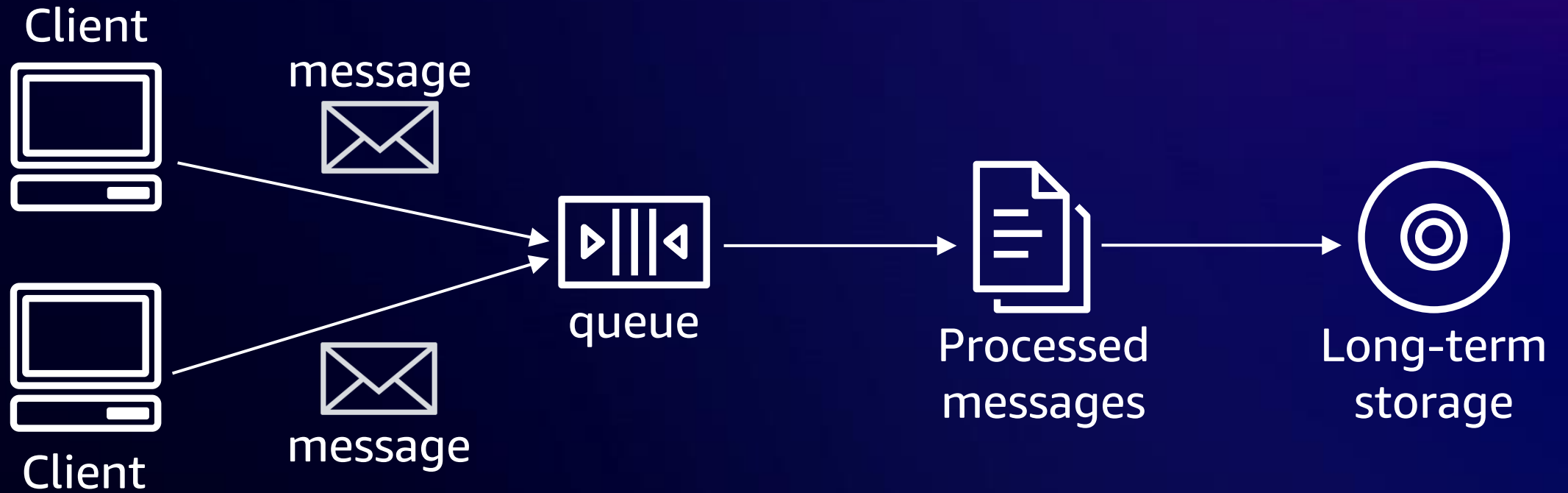
Amazon CloudWatch

Use Amazon CloudWatch metrics and events to **monitor important events and API calls** in your AWS accounts

Examples

- Metrics: Time until key/certificate expiration
- Events: Key rotation, key deletion, imported key expiration, certificate renewal

Problem



Amazon Comprehend PII detection

Hi, my name is John Doe. For verification, the last 4 digits of my social are 6789 and my dob is 01/01.

I paid for my credit card 1111-0000-1111-0000 last week from my bank account XXXXXX1111 with the routing number XXXXX0000. The check was mailed from 100 Main Street, Anytown, WA 98121.

Please confirm receipt by calling me at 206-555-0199 or emailing at john.doe@anycompany.com.

Entity	
John Doe	NAME
6789	SSN
01/01	DATE_TIME
1111-0000-1111-0000	CREDIT_DEBIT_NUMBER
XXXXXX1111	BANK_ACCOUNT_NUMBER
XXXXX0000	BANK_ROUTING
100 Main Street, Anytown, WA 98121	ADDRESS
206-555-0199	PHONE
john.doe@anycompany.com	EMAIL

PII elements detected

FOR EACH DETECTED PII ENTITY, YOU GET THE TYPE OF PII,
A CONFIDENCE SCORE, AND BEGINNING AND ENDING OFFSET

PII ENTITY CATEGORY					
	Financial	Personal	Technical security	National	Other
PII ENTITY TYPES	BANK_ACCOUNT_NUMBER	NAME	USERNAME	SSN	DATE_TIME
	BANK_ROUTING	ADDRESS	PASSWORD	PASSPORT_NUMBER	
	CREDIT_DEBIT_NUMBER	PHONE (10 digits)	URL	DRIVER_ID	
	CREDIT_DEBIT_CVV	EMAIL	AWS_ACCESS_KEY		
	CREDIT_DEBIT_EXPIRY	AGE	AWS_SECRET_KEY		
	PIN		IP_ADDRESS MAC_ADDRESS		

Amazon Comprehend understands PII

The screenshot displays the Amazon Comprehend Insights dashboard. The 'PII' tab is selected, showing a list of detected personal information entities. The analyzed text is a paragraph containing various personal details. The results table lists each entity, its type, and a confidence score of 0.99+.

Insights [Info](#)

Entities | Key phrases | Language | **PII** | Sentiment | Syntax

Analyzed text

Good morning, everybody. My name is Van Bokhorst Serdar, and today I feel like sharing a whole lot of personal information with you. Let's start with my Email address SerdarvanBokhorst@dayrep.com. My address is 2657 Koontz Lane, Los Angeles, CA. My phone number is 818-828-6231. My Social security number is 548-95-6370. My Bank account number is 940517528812 and routing number 195991012. My credit card number is 5534816011668430. Expiration Date 6/1/2022, my C V V code is 121, and my pin 123456. Well, I think that's it. You know a whole lot about me. And I hope that Amazon comprehend is doing a good job at identifying PII entities so you can redact my personal information away from this document. Let's check.

Results

Search < 1 2 > ⚙

Entity	Type	Confidence
Van Bokhorst Serdar	NAME	0.99+
SerdarvanBokhorst@dayrep.com	EMAIL	0.99+
2657 Koontz Lane, Los Angeles, CA.	ADDRESS	0.99+
818-828-6231	PHONE	0.99+
548-95-6370	SSN	0.99+
940517528812	BANK_ACCOUNT_NUMBER	0.99+
195991012	BANK_ROUTING	0.99+
5534816011668430	CREDIT_DEBIT_NUMBER	0.99+
6/1/2022	CREDIT_DEBIT_EXPIRY	0.99+
121	CREDIT_DEBIT_CVV	0.99+

Amazon Comprehend understands PII continued

PII detection settings

Output mode

☐ Offsets
The job output provides character offsets that locate each PII entity in the input text.

☒ Redactions
The job returns a copy of the input text in which each PII entity is redacted.

Select the types of PII entities to redact

▼ PII entity types (22 of 22 selected)

☒ Select all

☒ Financial (6 selected) ☒ BANK_ACCOUNT_NUMBER ☒ BANK_ROUTING ☒ CREDIT_DEBIT_NUMBER ☒ CREDIT_DEBIT_CVV ☒ CREDIT_DEBIT_EXPIRY ☒ PIN	☒ Personal (5 selected) ☒ NAME ☒ ADDRESS ☒ PHONE ☒ EMAIL ☒ AGE	☒ Technical security (7 selected) ☒ USERNAME ☒ PASSWORD ☒ URL ☒ AWS_ACCESS_KEY ☒ AWS_SECRET_KEY ☒ IP_ADDRESS ☒ MAC_ADDRESS
☒ National (3 selected) ☒ SSN ☒ PASSPORT_NUMBER ☒ DRIVER_ID	☒ Other (1 selected) ☒ DATE_TIME	

Redaction mode

☒ Replace with PII entity type
Each PII entity is replaced with its type. For example, Jane Doe is replaced with [NAME].

☐ Replace with character
The characters in PII entities are replaced with a character of your choice. For example, Jane Doe is replaced with ****.*.

Identify and prevent sensitive data leakage for log and message data in transit



Applications are producing, distributing, and exchanging growing volumes of data



Increasingly challenging to comply with data privacy regulations



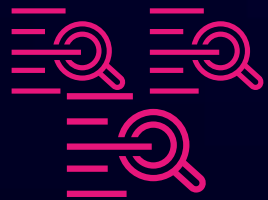
Customers take on the expense to custom-build and manage their own data protection capabilities

Real-time scanning, detection, and protection for logs and messages

Inbound logs and messages

Data protection policy evaluation
and real-time scanning

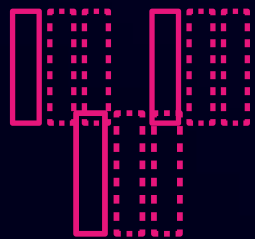
Actions to protect data



Logs



Amazon
CloudWatch



Messages



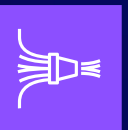
Amazon SNS



De-identify

Emit audit
findings

Deny (SNS only)



Anatomy of data protection policies

Data protection policy



Policies are associated to log groups and topics

1 Policy config

- Name
- Description
- Version
- Data direction (SNS only)
- Principals (SNS only)

2 Data identifiers

- Personal identifiable information (PII)
- Protected health information (PHI)
- Financial
- Credentials and devices

Leverages regular expressions & AI/ML

3 Actions

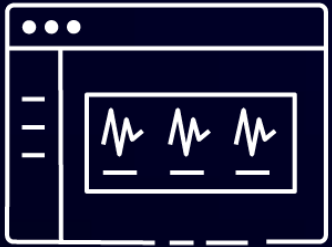
- Audit (incl. sample rate)
- De-identify
- Deny (SNS only)

4 Finding destinations

- Amazon S3
- Amazon Kinesis Data Firehose
- Amazon CloudWatch

Key benefits

Scalable



- No throughput quotas
- Minimal incremental latency

Sensitive data visibility



- Identify sensitive data
- Emit logs or metrics and set alarms

Centrally managed



- Pre-defined, managed data identifiers
- Re-usable policies

Act to prevent data leakage



- De-identify data via redaction or masking
- Deny delivery of data

Managed data identifiers

Personal (PII)



- Passport number
- Social Security number
- Driver's license number

Health (PHI)



- Health insurance number
- National drug code
- NHS number

Financial



- Bank account number
- Credit card number
- Credit card expiration date

Credential & devices



- AWS secret access key
- OpenSSH private key
- IP address

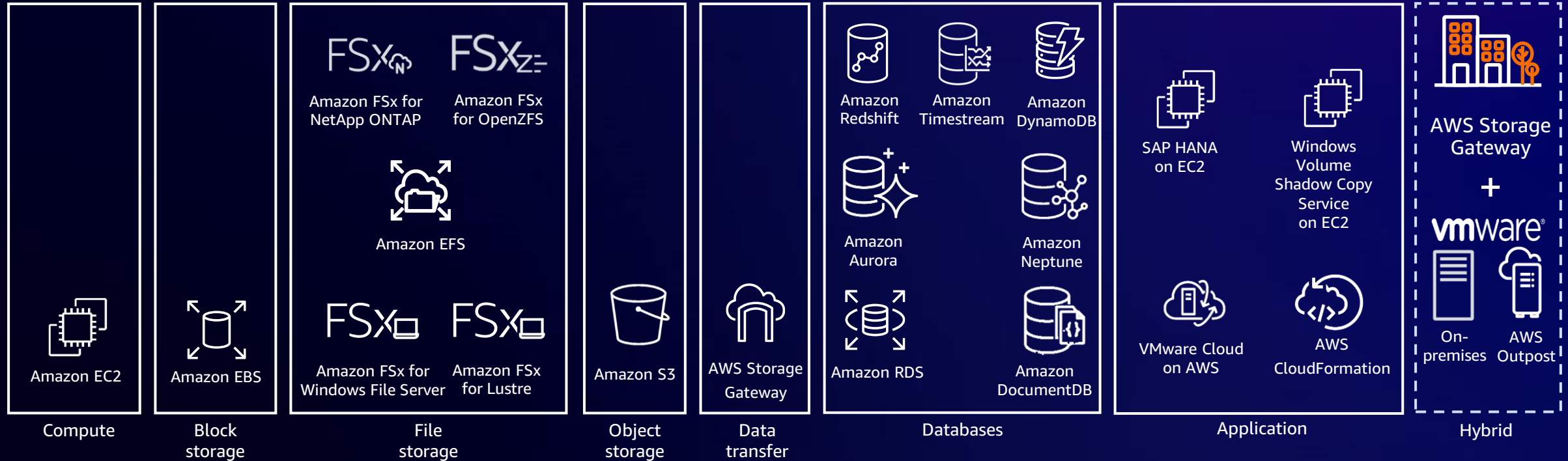
Over 100 identifiers across more than 5 languages

Overview of AWS Backup

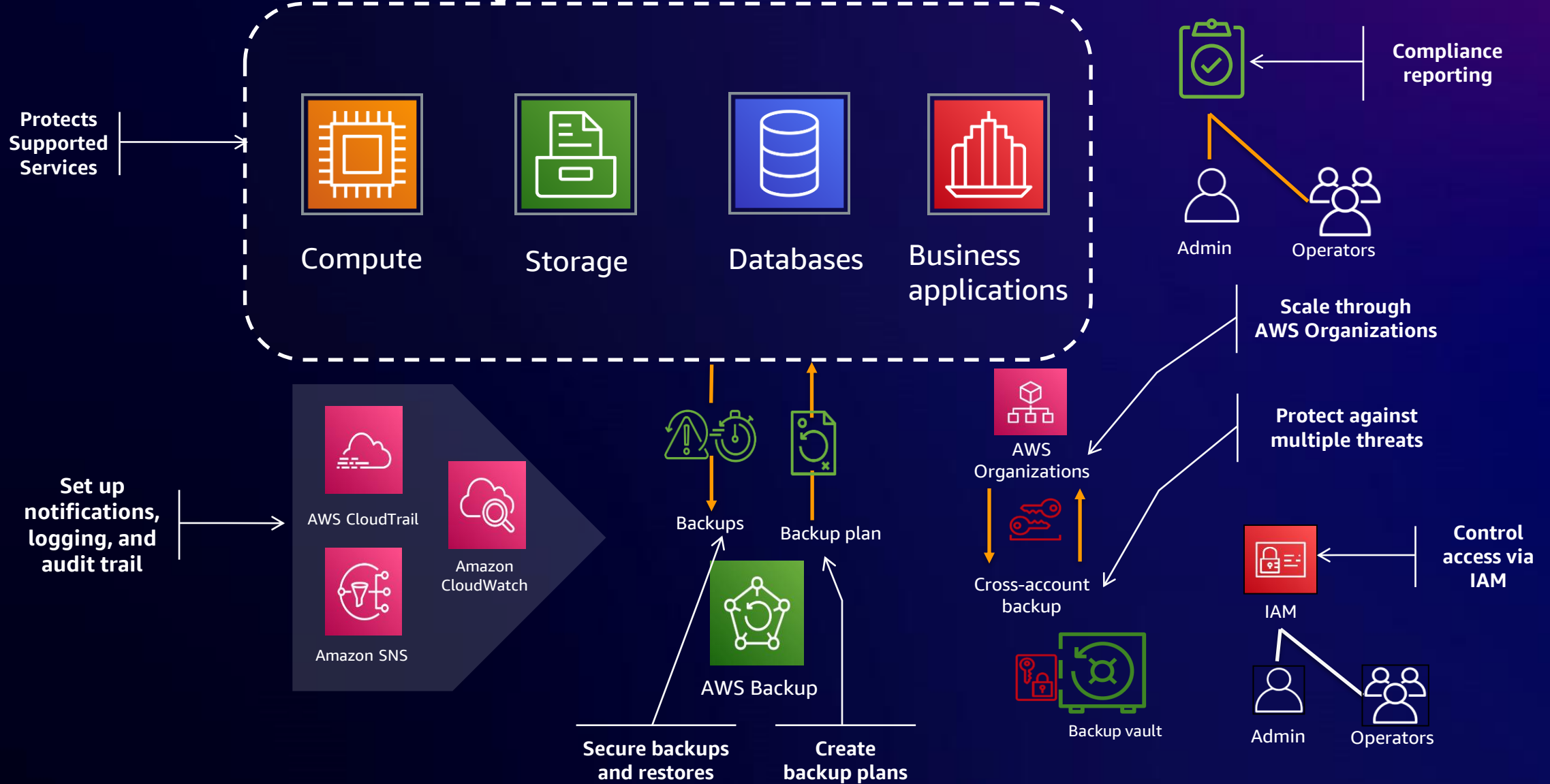


AWS Backup

A fully **managed, policy-based** backup service that makes it easy to **centrally manage and automate** the backup of data **across multiple AWS services** and hybrid workloads

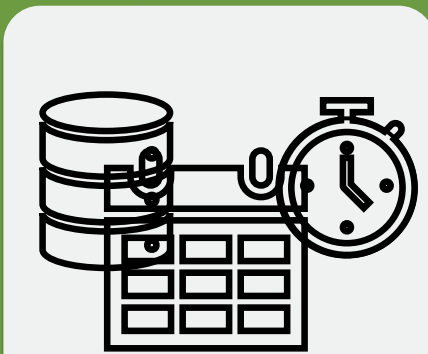


How AWS Backup works

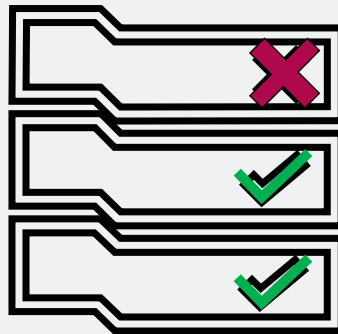


AWS Backup Audit Manager

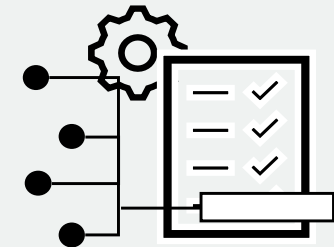
Monitor, evaluate, and demonstrate your backup compliance posture for centralized data governance



Continuously track
your backup activities



Automatically audit your
backup practices



Generate periodic and
on-demand audit reports

AWS Backup **Vault Lock**

AWS Backup **Vault Lock** protects your backups against malicious or accidental actions



Vault Lock
configuration



- **Attached to VAULT** – You enable **vault lock** configuration at the AWS Backup Vault level
- **Vault lock retention modes** – Governance, compliance and legal policies for immutability and data retention needs
- **Protects against deletion** – No user, including the root account, can delete your backups
- **Protects against lifecycle changes** – No user, including the root account, can change your backups' retention periods or update backups transition to cold storage settings
- **Enable vault lock** using **AWS Backup API, CLI, or SDK**

Compliance capabilities on AWS Backup

AUDIT AND REPORT WITH INSIGHTS ON COMPLIANCE STATUS OF DATA PROTECTION FRAMEWORKS



Cross-Region, cross-account support for organization-wide visibility and management

Legal holds prevent deletion of backups for ediscovery use cases

Cohasset certifies AWS Backup Vault Lock for SEC Rule 17a, FINRA Rule 4511(c), and CFTC Regulation 1.31(c)

Save the date for AWS re:Inforce

JUNE 10 - 12, 2024 | PHILADELPHIA, PA



AWS
re:Inforce



© 2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Thank you!



Please complete the session
survey in the mobile app

Don Edwards

[https://www.linkedin.com/in/
dmedwards/](https://www.linkedin.com/in/dmedwards/)

Peter M. O'Donnell

[https://www.linkedin.com/in/
petermodonnell/](https://www.linkedin.com/in/petermodonnell/)

